Enrico Bravi

enrico.bravi@polito.it

Module G – IoT Security

G1 – Introduction to IoT Security

Politecnico di Torino

1859

Department of Control and Computer Engineering

DAUIN

TORSEC

Computer and Network Security Group

Acknowledgments

This lecture deck *adapts* and *reorganizes* selected teaching material originally developed by Mr. Rajasekar V.R.. The presentation includes material from different, whose valuable help is here acknowledged and highly appreciated. Portions of the content are reused under the Creative Commons BY-NC license (see license slide). All modifications, additions, re-organization, and any errors are the responsibility of the course instructor.

License & Disclaimer

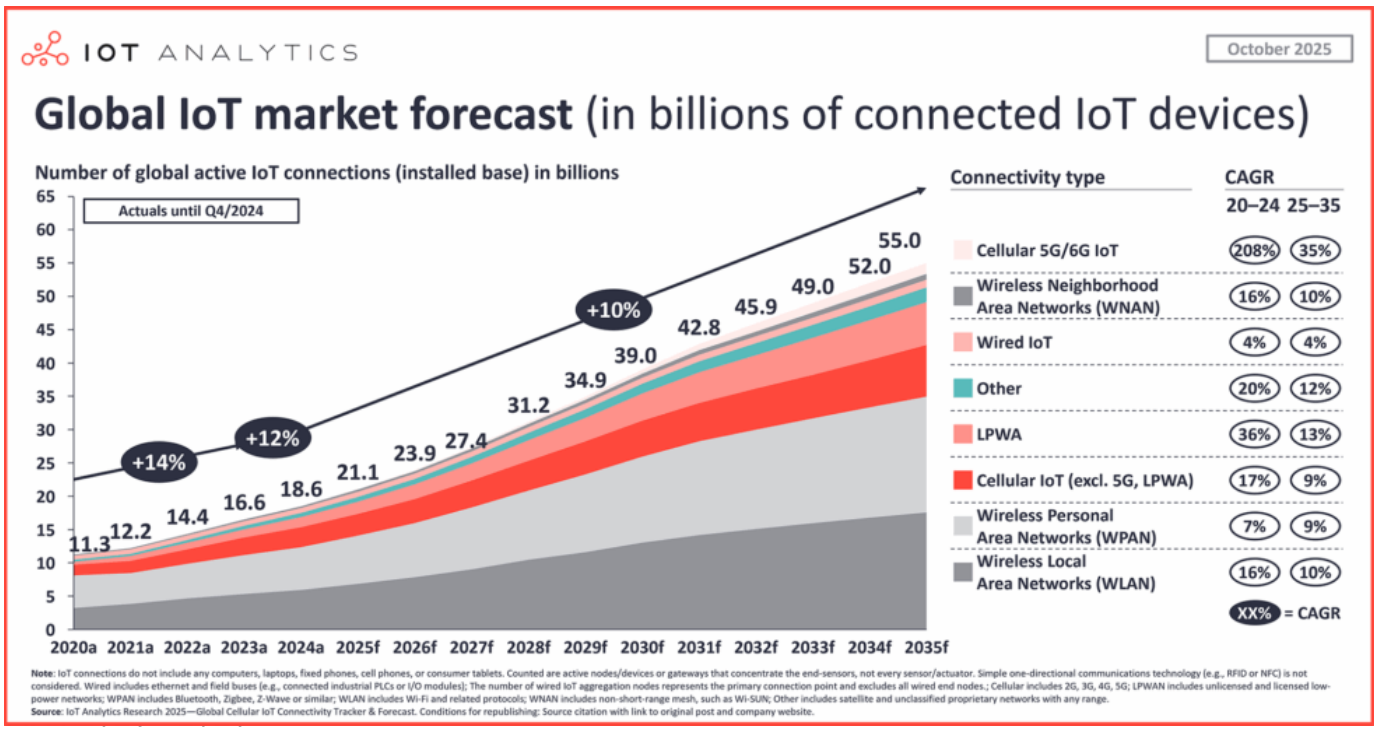
License Information

Disclaimer

- We disclaim any warranties or representations as to the accuracy or completeness of this material.
- Materials are provided “as is” without warranty of any kind, either express or implied, including without limitation, warranties of merchantability, fitness for a particular purpose, and non-infringement.
- Under no circumstances shall we be liable for any loss, damage, liability or expense incurred or suffered which is claimed to have resulted from use of this material.
- This material is used and adapted within the course “Cybersecurity and National Defense”.

The IoT Era (I)

- the current Internet connects countless devices using unified communication frameworks to deliver services directly to users
- experts predict that within a few years, tens of billions of these devices will be connected to the network



[source – IOT ANALYTICS]

The IoT Era (II)

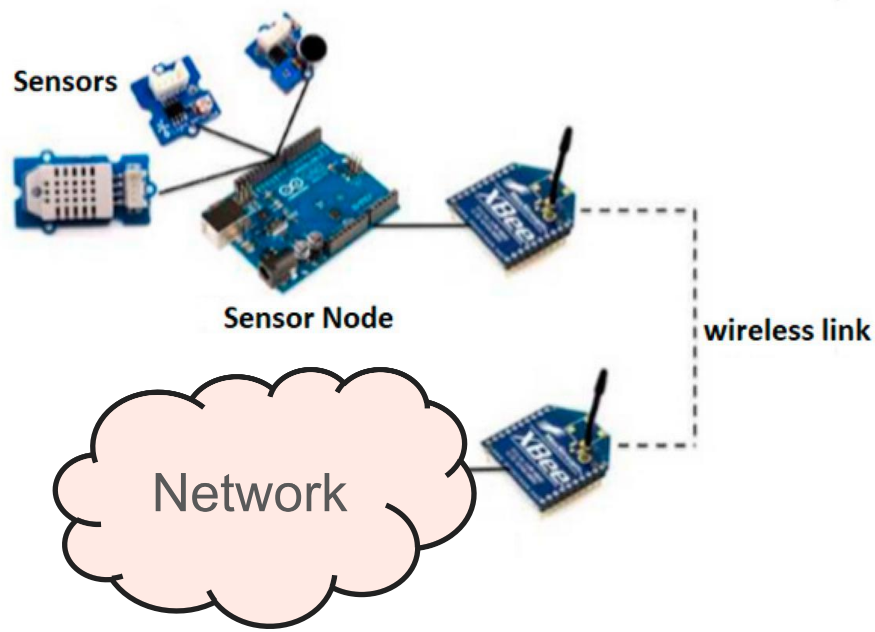
- this connectivity permits novel interactions bridging the physical environment with computing power, digital media, data analytics, applications, and services
- this emerging network model is widely known as the Internet of Things (IoT)
- IoT introduces advantages for consumers, manufacturers, and service providers across diverse industries
- key sectors benefiting from IoT include healthcare, home automation, energy, agriculture, transportation, environment, inventory, security, and education

IoT Definitions (I)

- ITU-T Y.2060 defines IoT as a global infrastructure connecting physical and virtual things via interoperable communication technologies to enable advanced services
- a Thing is any identifiable physical or virtual object linked to communication networks
- an IoT Device must support communication and may include sensing, actuation, data capture, storage, and processing.
- IoT combines physical objects, controllers, sensors, actuators, and the Internet.

IoT Definitions (II)

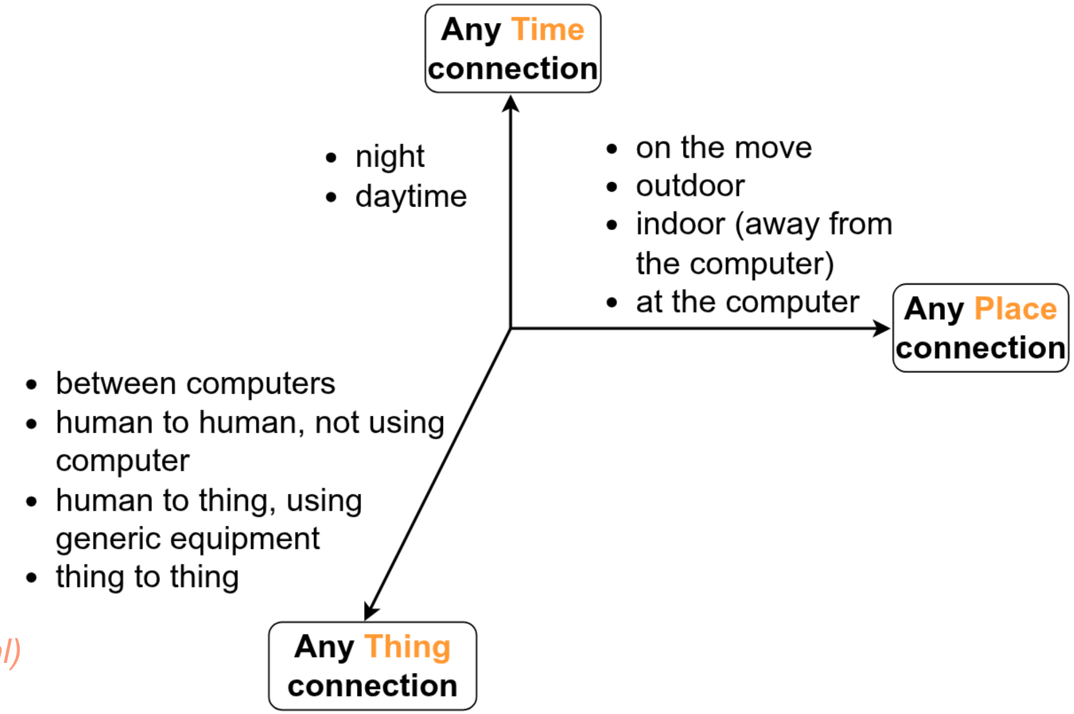
- each IoT object typically has:
  - a microcontroller for intelligence
  - sensors or actuators for interacting with physical parameters
  - network connectivity for communication



[source]

IoT Dimension of Connection

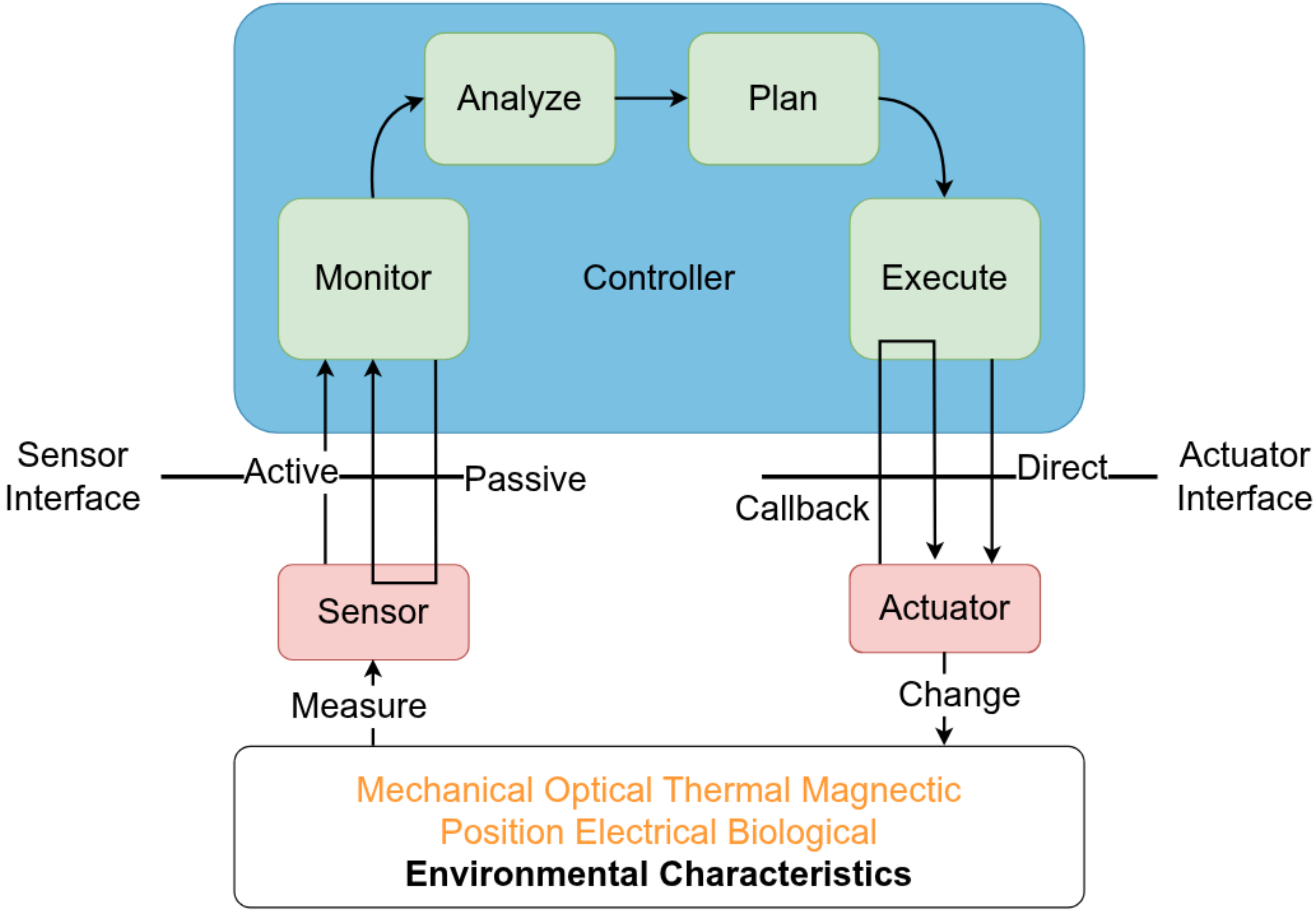
- IoT introduces a new layer to information and communication technologies by enabling communication among any thing
- this complements the existing capabilities of communication at any time and communication from any location



IoT Thing Components (I)

- an IoT device has some key parts: sensors, actuators, a small computer (microcontroller), a way to communicate (like a transceiver), and an ID to identify it
- communication is very important; without it, the device can't join a network
- most IoT devices have some computing power, even if it's basic, and may have one or more of the other parts

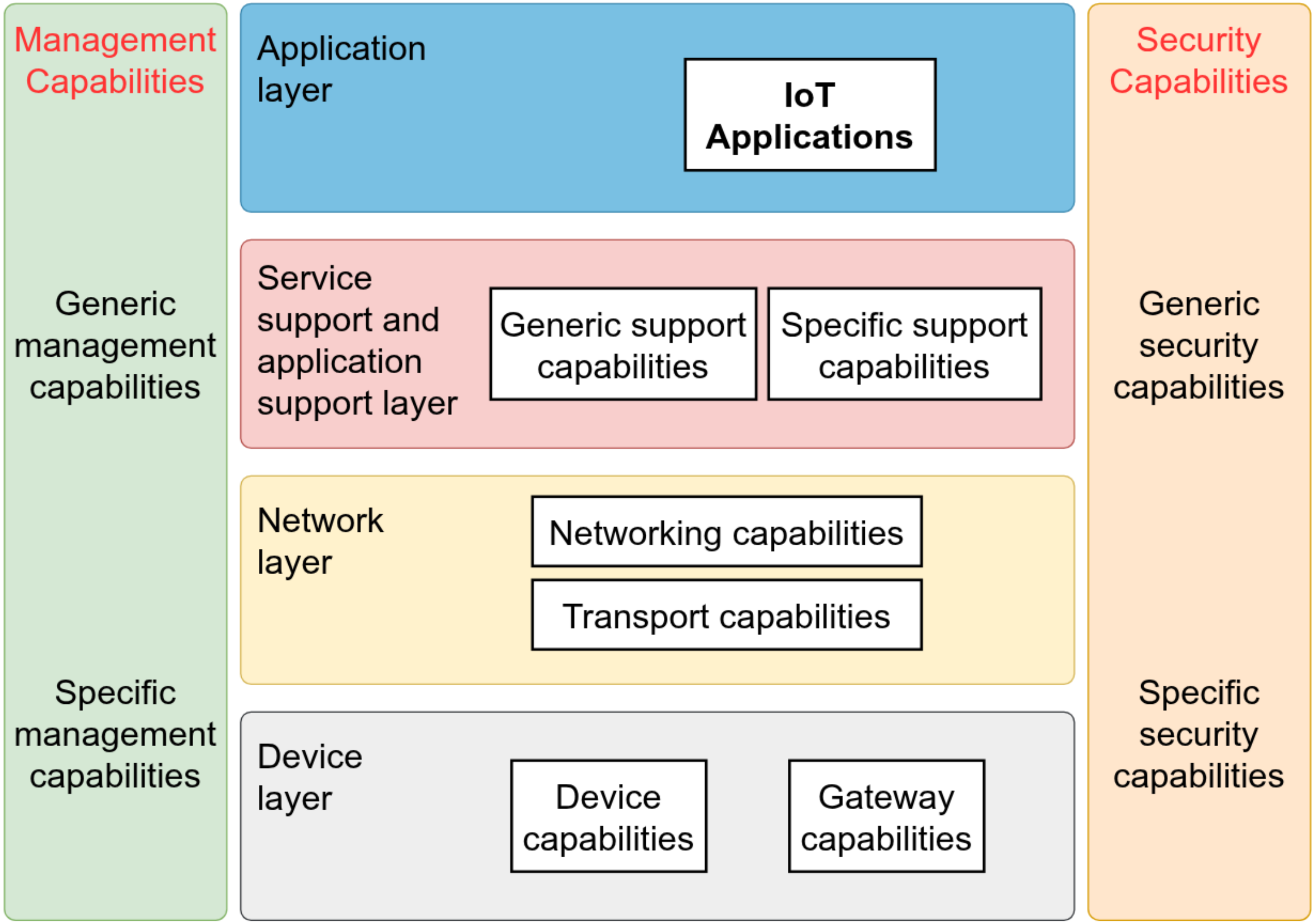
IoT Thing Components (II)



IoT Reference Model (I)

- the International Telecommunication Union Telecommunication Standardization Sector (ITU-T) IoT reference model is organized into four layers, each supported by comprehensive management and security functions that operate across all levels
- in terms of communication roles, the device layer mainly corresponds to the physical and data link layers defined in the OSI model, handling fundamental connectivity tasks
- the security capability layer aims to include some generic security features, remaining independent from the applications

IoT Reference Model (II)



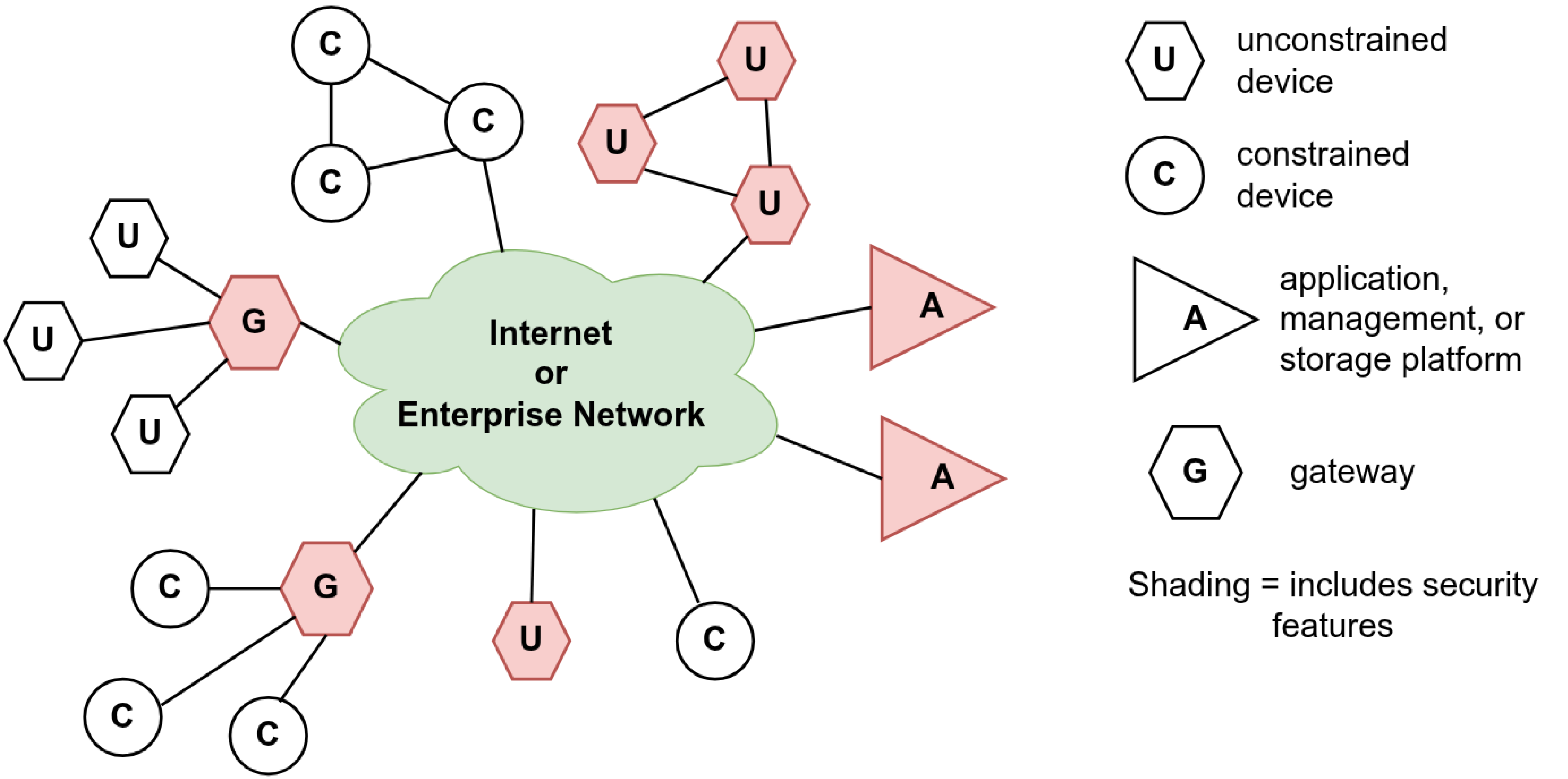
IoT Security (I)

- the IoT represents one of the most intricate and least mature sectors in network security
- central to the network are the application platforms, data repositories, and systems responsible for network and security management
- these core systems collect sensor data, dispatch commands to actuators, and oversee the operation and communication of IoT devices
- positioned at the network’s edge are IoT devices, ranging from simple, resource-limited units to more advanced, capable devices

IoT Security (II)

- gateways often facilitate protocol translation and provide additional networking services for these IoT devices
- the shaded areas in the figure denote systems that support security protocols such as TLS and IPSec
- more sophisticated devices may include some security features, though this is not guaranteed
- devices with limited resources typically have minimal or no built-in security measures
- gateway devices play a crucial role in enabling secure communication between the gateway itself and central systems like application and management platforms

IoT Security (III)



IoT Security Requirements (I)

- the ITU-T Recommendation Y.2066 outlines essential security requirements for the IoT
- Communication Security: ensuring communication within IoT systems is secure, trustworthy, and respects privacy, preventing unauthorized data access, guaranteeing data integrity, and safeguards sensitive information during transmission or transfer
- Data Management Security: protecting data storage and processing by enforcing secure, reliable, and privacy-protected management, blocking unauthorized data access, maintains data accuracy, and shields privacy-related information when storing and processing data

IoT Security Requirements (II)

- Service Provision Security: guaranteeing that IoT services are delivered securely and reliably, preventing unauthorized use and fraudulent activities, also ensuring the protection of user privacy related to IoT services
- Integration of Security Policies and Techniques: it's essential to seamlessly combine various security policies and methods to maintain consistent protection across the diverse range of IoT devices and user networks

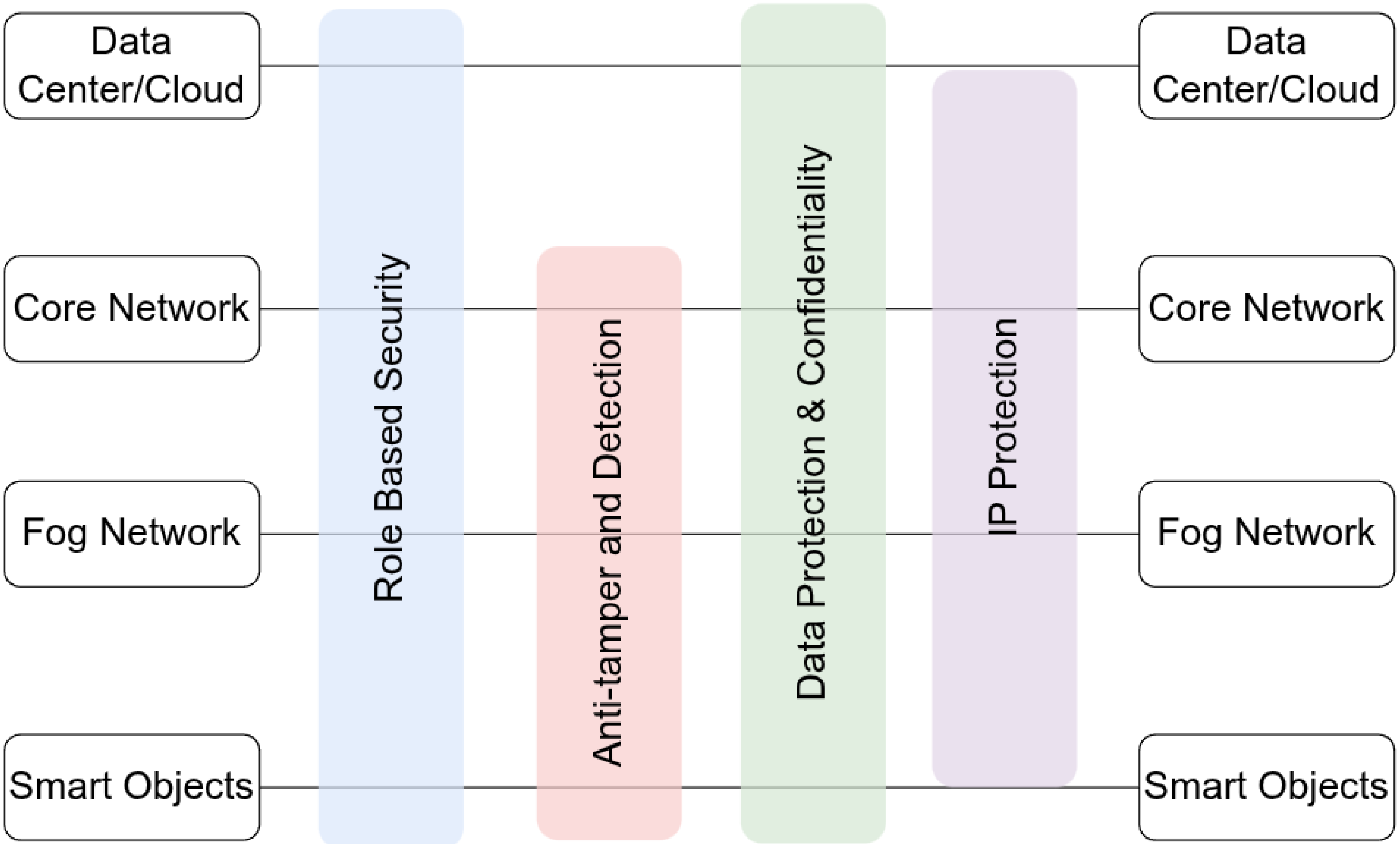
IoT Security Requirements (III)

- Mutual Authentication and Authorization: before granting access to the IoT ecosystem, both the device (or user) and the IoT platform must verify each other’s identities and permissions based on established security protocols
- Security Audit: IoT systems must support thorough security audits, ensuring that every data access or access attempt is fully transparent, traceable, and reproducible in compliance with relevant laws and regulations, including auditing data during transmission, storage, processing, and application usage

IoT Security Framework (I)

- the diagram in the next slide depicts the security landscape associated with the logical framework of the IoT
- this IoT framework is a simplified version of the World Forum IoT Reference Model
- It is organized into several distinct layers:
    - Smart Objects
    - Fog Network
    - Core Network
    - Data Center/Cloud

IoT Security Framework (II)



Smart Devices/Embedded Systems

- these components include sensors, actuators, and various embedded devices positioned at the network's edge
- often, these devices operate in environments lacking physical security
- ensuring continuous availability is critical, alongside verifying the authenticity and integrity of sensor-generated data
- it is also essential to safeguard actuators and smart devices against unauthorized access, protect user privacy, and prevent eavesdropping

Edge and Fog Networks

- this layer focuses on the wired and wireless connectivity that links IoT devices
- a major challenge lies in managing the diverse range of network technologies and communication protocols employed by different IoT devices
- establishing and enforcing a consistent security framework across these varied systems is crucial

Core Network

- it acts as the link for data transmission between central network hubs and IoT devices
- faces security challenges similar to those found in conventional core networks
- the high volume of endpoints requiring interaction and management significantly amplifies the security complexity

Data Center/Cloud

- it hosts the applications, data repositories, and network management systems
- IoT does not introduce fundamentally new security concerns at this layer, aside from the challenge of managing an enormous number of individual endpoints

Security Capabilities (I)

- in this four-layered framework, four security features operate across multiple layers
- Role-Based Access Control (RBAC)
  - instead of assigning permissions to individual users, RBAC allocates access rights to specific roles
  - users are then linked to these roles, either permanently or temporarily, based on their duties
  - RBAC is widely adopted in commercial cloud and enterprise environments and serves as a proven method to regulate access to IoT devices and their generated data

Security Capabilities (II)

- Tamper Resistance and Detection
  - this capability is crucial primarily at the device and fog network layers but also applies to the core network
  - components at these levels may be physically located outside the enterprise’s secured perimeter, making tamper detection vital
- Data Security and Privacy
  - these protections are implemented throughout every layer of the architecture to safeguard sensitive information

Security Capabilities (III)

- Internet Protocol Security
  - ensuring the confidentiality and integrity of data as it travels between layers is essential to prevent interception and unauthorized monitoring

Security Challenges in IoT (I)

- beyond just cost concerns and the widespread presence of devices, IoT faces several other critical security challenges
- Unpredictable Behavior
  - the vast number of devices deployed, combined with the diverse technologies they employ, leads to behaviors in real-world settings that can be difficult to anticipate
  - even if a particular system is carefully engineered and managed, its interactions with other systems remain uncertain and potentially risky

Security Challenges in IoT (II)

- Device Homogeneity
  - many IoT devices share similar designs
  - they often rely on identical connectivity methods and hardware components
  - consequently, a vulnerability found in one device or system is likely to affect many others
- Challenges in Deployment
  - a key objective of IoT is to extend sophisticated networks and data analytics into areas previously unreachable
  - however, this ambition introduces the difficulty of physically protecting devices placed in unusual or easily accessible locations

Security Challenges in IoT (III)

- Extended Device Life and End of Support
  - IoT devices are known for their durability and long operational life, but this longevity often means they may continue functioning beyond the period during which manufacturers provide support
  - in contrast, traditional systems usually receive support and updates even after many users have stopped using them
  - devices that become “orphaned” or abandoned lack ongoing security enhancements, making them vulnerable as technology advances

Security Challenges in IoT (IV)

- Lack of Upgrade
  - many IoT devices, similar to various mobile and compact devices, are not built to support software frequent upgrades or modifications
  - some devices do offer updates, but these are often inconvenient to apply, leading many users to overlook or ignore them

Security Challenges in IoT (V)

- Limited Transparency
  - a significant number of IoT devices do not offer transparency for their operations
  - users are unable to monitor or control the device’s internal processes and must rely on assumptions about their behavior
  - there is no user control over unwanted features or data collection, and manufacturer updates can introduce additional undesired functionalities

Security Challenges in IoT (VI)

- Absence of Alerts
  - IoT aims to deliver powerful features without disrupting users, but this can result in a lack of user awareness
  - users often do not actively monitor their devices or recognize when issues arise
  - security breaches may go unnoticed for extended periods, increasing risk

Cybersecurity Threats in IoT (I)

- the vulnerabilities inherent in IoT devices, combined with their operational capabilities, expose users and providers to potential liabilities
- the primary concerns revolve around three critical areas: device failures, cyberattacks, and unauthorized data access
- these challenges can lead to a broad spectrum of harmful consequences

Cybersecurity Threats in IoT (II)

- Device Failures
  - IoT technology brings advanced automation that can control critical systems affecting both safety and property
  - malfunctions in these systems can trigger serious damage; for instance, a fault in an IoT-controlled heating system might cause pipes to freeze and burst in an empty house, leading to water damage
  - this risk forces organizations to implement robust safeguards

Cybersecurity Threats in IoT (III)

- Data Breaches
  - data is both the greatest asset and the biggest vulnerability of IoT
  - various actors are drawn to this data for reasons including marketing exploitation, identity theft, wrongful incrimination, stalking, or simply malicious intent
  - the security measures designed to prevent attacks also help mitigate the risk of data theft

Cybersecurity Threats in IoT (IV)

- Cyber Attacks
  - IoT devices can open up entire networks and connected systems to potential cyber threats
  - while these connections boost integration and efficiency, they also create vulnerabilities (imagine a compromised smart oven or a tampered fire sprinkler system causing attacks)
  - the most effective defenses focus on securing the weakest links and tailoring protections like continuous monitoring and controlled access

Cybersecurity Threats in IoT (V)

- some straightforward yet powerful strategies include:
  - Built-in Security: devices designed with security features built directly into their hardware and firmware
  - Encryption: essential at both the manufacturing stage and within user environments to safeguard data
  - Risk Analysis: both individuals and organizations should evaluate potential risks when designing or selecting IoT systems
  - Access Control: whenever feasible, devices should enforce strict privilege levels and authentication methods to limit unauthorized use

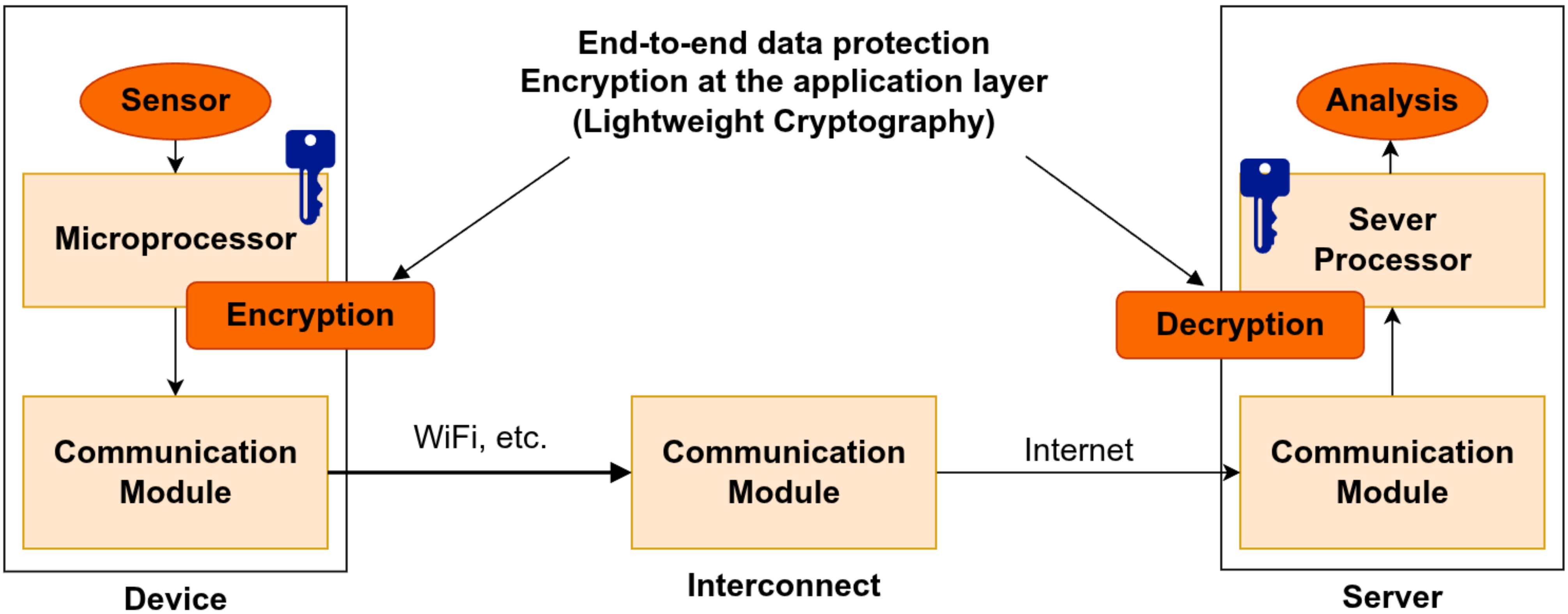
IoT Security Countermeasures

- essential Security Technologies in Use
  - data encryption techniques
  - password-based protection
  - dedicated Hardware Security Modules (HSMs)
  - Multi-Factor Authentication (MFA)
  - Trusted Execution Environment (TEE)
  - comprehensive data wiping methods
  - Public Key Infrastructure (PKI) certificates
  - biometric verification systems
  - specialized Hardware Cryptographic Processors
  - distributed ledger technology (Blockchain)

Encryption (I)

- Lightweight Cryptography refers to cryptographic methods specifically designed for devices with limited resources, such as RFID tags, sensors, contactless smart cards, and medical equipment
- these lightweight cryptographic techniques improve traditional algorithms commonly employed in Internet security protocols like IPsec and TLS
- despite their streamlined design, lightweight cryptography provides robust security suitable for many applications
- however, lightweight cryptography does not always fully leverage the balance between security strength and operational efficiency

Encryption (II)



Password-based Protection

- relying on passwords for authenticating IoT devices is becoming less viable for two main reasons
  - many IoT devices have limited capabilities, making it difficult for them to handle password storage or processing
  - passwords are not well-suited for automated authentication since they typically require human input, which complicates seamless machine-to-machine communication
- consequently, passwords fall short as a security measure for automated data exchanges in IoT environments

Hardware Security Modules (HSMs)

- an HSM is a dedicated physical device designed to protect and manage digital keys, ensuring robust authentication and performing cryptographic operations
- typically, HSMs are available as either plug-in cards or standalone external units that connect directly to computers or network servers
- key capabilities of an HSM include:
  - secure generation of cryptographic keys within the device
  - secure storage and administration of these keys
  - handling of cryptographic processes and sensitive data securely
  - relieving application servers by executing both asymmetric and symmetric cryptographic tasks independently

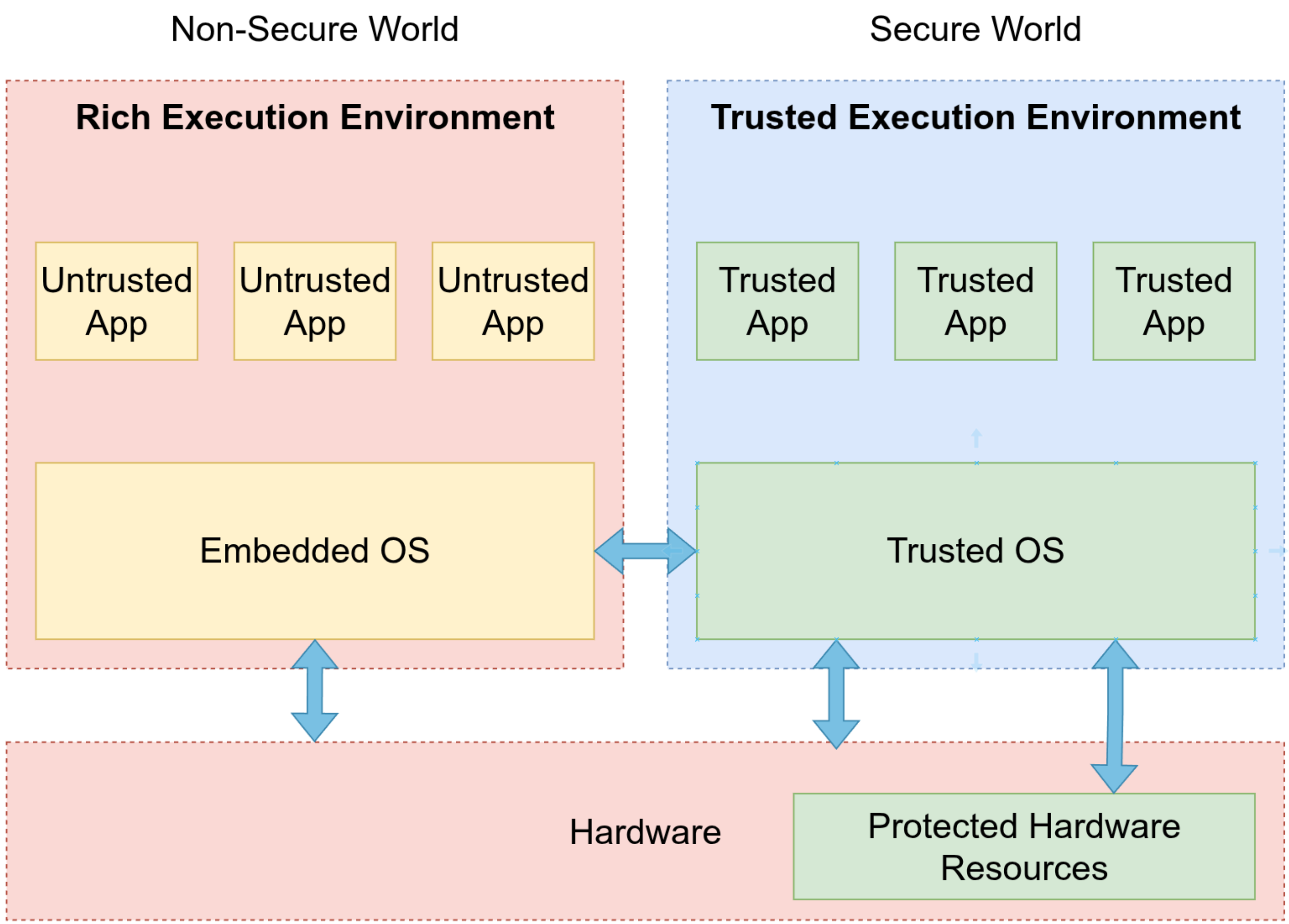
Multi-Factor Authentication (MFA)

- MFA or Two-factor authentication (2FA) are security methods requiring users to present two distinct forms of identification to confirm their identity
- this approach differs from single-factor authentication (SFA), where only one credential, usually a password, is needed
- by adding extra verification steps, MFA significantly strengthens security, making unauthorized access much more difficult for attackers
- for many years, MFA has been a trusted mechanism to safeguard access to critical systems and confidential information
- organizations implement MFA to protect their users' data from being compromised by cyber threats.

Trusted Execution Environment (TEE) (I)

- TEEs are hardware security extensions of CPUs
- they create shielded and protected environments for execute critical code and sensitive data
- they are suitable for the entire IoT system’s layers (e.g., ARM, Intel, AMD, Qualcomm)
- it provides isolation at hardware level among software components

Trusted Execution Environment (TEE) (II)



Secure Element

- a Secure Element is a robust, tamper-proof hardware module integrated into IoT devices and industrial machinery, providing security comparable to smart cards and managing the device's entire lifecycle
- it acts as the root of trust within sophisticated end-to-end security frameworks, safeguarding data integrity and shielding systems from cyber threats
- Secure Elements guarantee that sensitive information is securely stored and accessible exclusively to authorized users and applications
- they also support remote, over-the-air updates for security credentials, software patches, and evolving protection features throughout the solution's lifespan

Data Erasure

- data erasure, also known as data clearing or wiping, are software or hardware –based technique that overwrites existing information on digital storage devices, such as hard drives, by replacing it with binary data (zeros and ones)
- this process ensures that the original data is completely removed, making it impossible to recover and effectively sanitizing the storage medium
- effective data erasure techniques should:
  - offer the option to choose from various standards tailored to specific requirements
  - confirm that the overwriting process has been thoroughly executed across the entire device, guaranteeing complete data removal

PKI Certificates

- Public Key Infrastructure (PKI) incudes the roles, policies, and procedures essential for generating, managing, distributing, utilizing, storing, and revoking digital certificates, as well as overseeing public-key encryption
- PKI's main goal is to enable secure electronic communication across various network services, including e-commerce, online banking, and confidential email exchanges
- it becomes crucial in scenarios where simple password authentication is inadequate, requiring stronger verification methods to confirm the identities of communicating parties and ensure the integrity of the transmitted data

Biometrics

- biometric authentication involves matching an individual’s unique physical or behavioral traits against a stored biometric template to verify identity
- initially, the reference biometric data is saved either in a secure database or on a protected portable device such as a smart card
- when authentication is needed, the system compares the live biometric input with the stored template
- this process focuses on confirming the person’s identity with high accuracy

Hardware Crypto Processor

- a secure cryptoprocessor is a specialized microprocessor or chip designed exclusively to perform cryptographic functions
- it is placed within a package protected with multiple physical security features, providing robust resistance against tampering
- unlike standard cryptographic processors that may expose decrypted data on a bus within a secure setting, a secure cryptoprocessor ensures that decrypted data or program instructions never leave the protected environment where security cannot be guaranteed
- the main role of a secure cryptoprocessor is to serve as the foundational element of a security subsystem, removing the necessity to apply physical security protections to the rest of the subsystem

Blockchain (I)

- a blockchain is a type of database designed to store an ever-expanding collection of data entries
- it operates in a decentralized manner, meaning no single central computer controls the entire chain
- every participant node holds its own complete copy of the blockchain
- the chain continuously grows as new data records are appended, never removed

Blockchain (II)

- the blockchain is composed of two fundamental components:
  - transactions: these are the activities initiated by users within the network
  - blocks: these group transactions together, ensuring they are chronologically ordered and protected against alteration, where each block also logs the exact time when its transactions were recorded

Blockchain (III)

- blockchain technology provides a method for securely recording transactions and digital interactions, ensuring transparency, robustness against failures, auditability, and operational efficiency
- this capability positions blockchain as a transformative force across various industries, paving the way for innovative business models
- integrating blockchain with the IoT improves the protection of data confidentiality and integrity
- this integration empowers connected devices to detect and counteract tampering and unauthorized alterations, thereby fostering greater trust among communicating parties